Universidad Veracruzana

Facultad de Estadística e Informática

Región: Xalapa

Licenciatura en Ingeniería en Ciberseguridad e Infraestructura de Cómputo

Medidas de seguridad a nivel de aplicación en el contexto de ataques de inyección de *prompt* dirigidos a sistemas basados en LLM: Una revisión de literatura

Presentación de avances de la revisión sistemática de literatura para la EE Proyecto Guiado



Presenta:
Abraham Núñez Sánchez

Director:
Héctor Xavier Limón Riaño

Noviembre de 2026

"Lis de Veracruz: Arte, Ciencia, Luz"

Problemática (1/2) – Problemática técnica

Greshake et al. (2023) mencionan que los sistemas que usan un LLM pueden procesar las instrucciones y datos en un mismo contexto, permitiendo que el contenido modificado por un atacante sea incorporado al contexto utilizado durante su funcionamiento.



- **En consecuencia, una inyección de *prompt* puede alterar el comportamiento esperado del sistema.**

Problemática (2/2) – Problemática en la información



- El conocimiento sobre las medidas de seguridad frente a los ataques de inyección de *prompt* se encuentra **disperso en la literatura**, particularmente en aquellas que pueden implementarse a nivel de aplicación.

Objetivos (1/3) - Objetivo general

Analizar las medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt* en sistemas basados en LLM, mediante la revisión de literatura científica, para identificar sus características, contextos de aplicación, alcances, limitaciones y criterios de evaluación.



Objetivos (2/3) - Objetivos específicos

- OE-01: Identificar los ataques de inyección de *prompt* que pueden ser mitigados desde el lado de la aplicación.
- OE-02: Analizar las medidas de seguridad a nivel de aplicación propuestas en la literatura reciente para mitigar los ataques de inyección de *prompt* en sistemas basados en LLM.
- OE-03: Clasificar las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema.

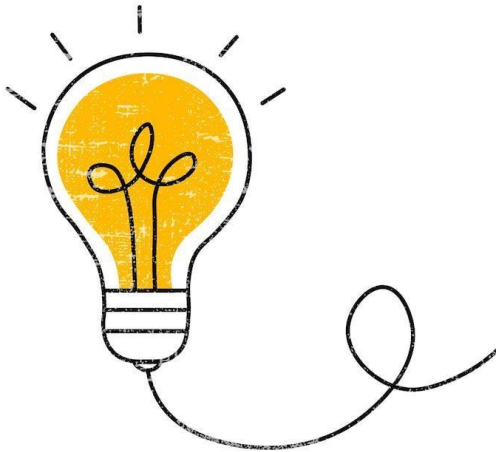
Objetivos (3/3) - Objetivos específicos

- OE-04: Identificar las taxonomías existentes para clasificar las mitigaciones de ataques de inyección de prompt a nivel de aplicación.
- OE-05: Analizar las formas en las que se evalúan las medidas de seguridad reportadas en la literatura considerando los tipos de ataques abordados, contextos de aplicación, criterios de evaluación, efectividad, impacto sobre la utilidad y limitaciones.
- OE-06: Discutir los alcances y limitaciones que permanezcan abiertos para futuras investigaciones.

Justificación

- Kumar et al. (2024) presentan un marco que clasifica diversos ataques de inyección de *prompt* según sus características, evidenciando la diversidad de estos ataques, además, de la necesidad de identificarlos y clasificarlos.

- Existen trabajos previos que permiten comprender qué ataques existen y qué estrategias de defensa han sido propuestas. Sin embargo, dichas revisiones abordan las defensas desde perspectivas amplias.



Delimitación de la revisión

Alcances

- Alcance de tipo descriptivo.
- Literatura científica entre los años 2022 al 2026.
- Literatura científica en idioma inglés.
- Literatura científica recuperable mediante plataformas académicas con acceso institucional.

Limitaciones

- Literatura científica que no pueda ser accedida por acceso institucional.
- Se excluirán trabajos no publicados formalmente o que no hayan pasado por un proceso de revisión.

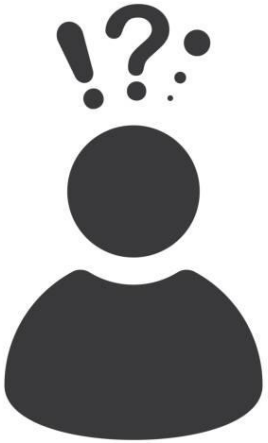
Revisiones Previas

Descripción	Aporte
Duarte et al. (2026) Realizan una revisión sistemática sobre ataques de inyección de *prompt*, abordando su evolución, taxonomías, métodos de evaluación y estrategias de defensa.	Proporcionar una visión estructurada del estado del campo e identificar oportunidades de investigación.
Geng et al. (2026) Analizan 128 estudios sobre métodos de ataque, causas de vulnerabilidad, defensas y evaluación.	Clasifican las defensas según su intervención, además de identificar limitaciones en los métodos de evaluación.
Woesle y Buettner (2026) Realizan una revisión sistemática de 89 publicaciones sobre ataques de inyección de prompt en sistemas integrados con LLM.	Proponen un marco de análisis basado en tres ejes: límite de confianza, objetivo del atacante y orientación de la investigación.

Motivación

- Existe una dispersión del conocimiento sobre las medidas de seguridad a nivel de aplicación, las propuestas aparecen en estudios con características diferentes.

- Las revisiones actuales permiten observar un panorama amplio de ataques y de medidas de mitigación, sin embargo, ninguna limita su análisis a las medidas que pueden implantarse a nivel de aplicación.



Preguntas de investigación (1/2)

- PI1. ¿Cuáles son los tipos de inyección de *prompt* a nivel de aplicación en los sistemas basados en LLM?
- PI2. ¿Qué medidas de seguridad a nivel de aplicación han sido propuestas en la literatura reciente para reducir los ataques de inyección de *prompt* en sistemas basados en LLM?
- PI3. ¿Qué tipo de categorías existen para las medidas de seguridad identificadas de acuerdo con el punto de intervención dentro del sistema basado en LLM?
- PI4. ¿En qué escenarios han sido implementadas las medidas de seguridad identificadas en la literatura?

Preguntas de investigación (2/2)

- PI5. ¿Cómo se evalúan las medidas de seguridad para determinar su efectividad contra los ataques de inyección?
- PI6. ¿Qué limitaciones y retos han sido reportadas para las medidas de seguridad analizadas contra ataques de inyección de prompt?
- PI7. ¿Qué líneas de trabajo futuro permanecen abiertas en la literatura sobre medidas de seguridad a nivel de aplicación frente a ataques de inyección de *prompt*?

Fuentes

- Se definieron las bibliotecas digitales para la búsqueda automática, las cuales fueron: IEEE Xplore, ACM Digital Library, SpringerLink y ScienceDirect.

- Estas bibliotecas son de las más empleadas para las revisiones sistemáticas en ingeniería de software, alojando diversas publicaciones ya arbitradas sobre el área.

Cadenas de búsqueda (1/4) – Quasi-Gold Standard

- Para la generación de cadenas de búsqueda preliminares, se empleó "Quasi-Gold Standard" propuesto por Zhang et al. (2011) y descrito por Kitchenham et al. (2016)., mediante una búsqueda manual de estudios que respondan al menos una pregunta de investigación.

- Se realizó una búsqueda manual en las bibliotecas elegidas, recabando un total de 39 estudios.

Motor de búsqueda	Estudios obtenidos
IEEE Xplore	10
ACM Digital Library	10
Springer Link	10
ScienceDirect	9

Cadenas de búsqueda (2/4) – *Keywords*

- El conjunto se sometió a un análisis para la extracción de palabras clave (*keywords*) por medio de un conteo palabras.

- Durante el conteo, se observó una tendencia en términos específicos como lo son "LLM", "*prompt injection*" y "*defense*".

Concepto	**Término relacionado**
Large Language Model	LLM LLM-based system
Ataque	Prompt Injection Indirect Prompt Injection Injection Attack
Defensa	Defense Detection Mitigation Prevention Attack detection Security Evaluation

Cadenas de búsqueda (3/4) – Evaluación de cadenas

- Las cadenas se redactaron de forma general y simple, evitando términos propios de un artículo para no sesgar la búsqueda hacia los estudios del QGS.

- El desempeño de las cadenas se evaluó con dos métricas de recuperación de información (Kitchenham et al., 2016; Zhang et al., 2011), calculadas respecto al QGS.

$$Cuasi - sensibilidad = \frac{R_{encontrados}}{R_{QGS}}$$

$$Cuasi - precisión = \frac{R_{encontrados}}{N_{total}}$$

Cadenas de búsqueda (4/4) – Evaluación de cadenas

ID	Cadena de búsqueda
CB1	**("large language model" OR LLM OR "LLM-based system") AND ("prompt injection" OR "indirect prompt injection") AND (defense OR detection OR mitigation OR prevention OR "attack detection")**
CB2	**("large language model" OR LLM OR "LLM-based system") AND ("prompt injection" OR "indirect prompt injection") AND (defense OR detection OR mitigation)**

Motor	Cadena	N_total	R_encontrados	R_QGS	Sensibilidad	Precisión
IEEE Xplore	CB1	206	9	10	0.9	0.043
ACM Digital Library	CB1	679	10	10	1	0.014
SpringerLink	CB1	712	10	10	1	0.014
ScienceNature	CB2	455	9	9	1	0.019

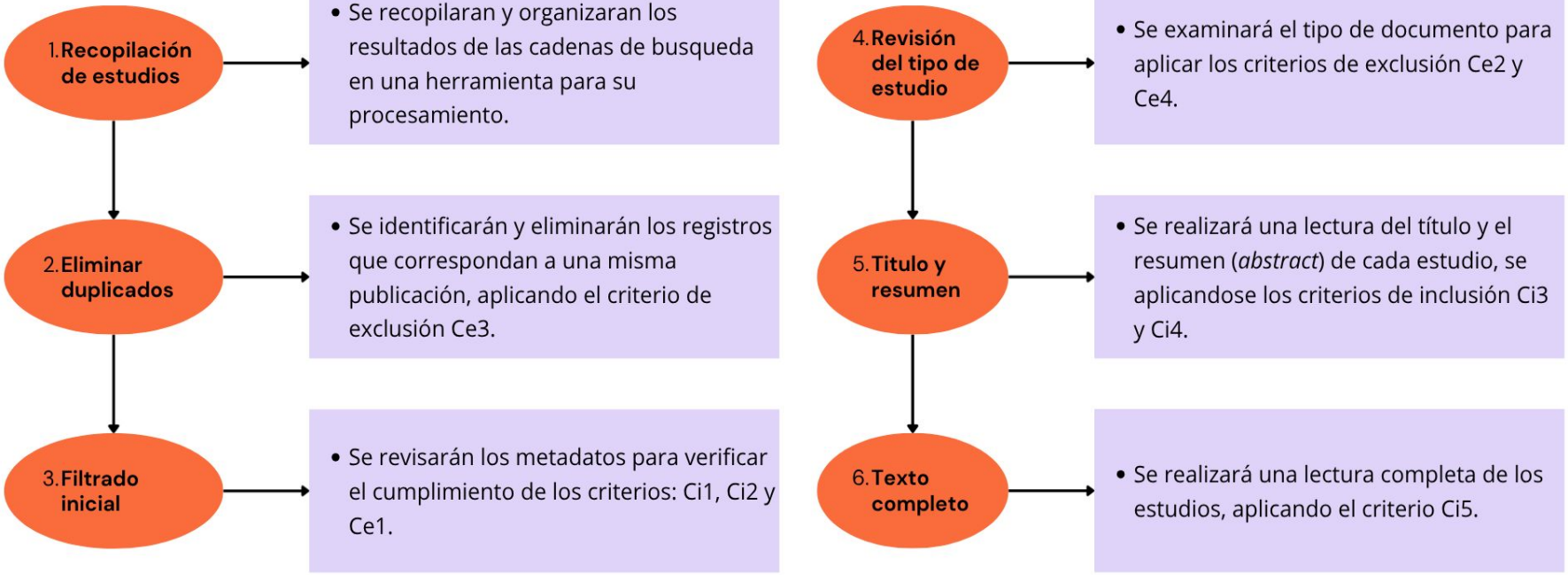
Selección de estudios (1/3) - Criterios de inclusión

Identificador	Criterio
Ci1	Estudios escritos en el idioma inglés.
Ci2	Estudios publicados entre enero de 2022 y la fecha de cierre de las búsquedas durante 2026.
Ci3	El título del estudio presenta indicios de responder al menos una pregunta de investigación.
Ci4	El resumen (*abstract*) del estudio presenta indicios de responder al menos una pregunta de investigación.
Ci5	El artículo responde al menos una pregunta de investigación

Selección de estudios (2/3) – Criterios de exclusión

Identificador	Criterio
Ce1	Artículos que no se puedan acceder a través de la biblioteca de la universidad.
Ce2	Se descartan revisiones sistemáticas, revisiones de literatura, mapeos sistemáticos y otros estudios secundarios.
Ce3	Se descartan artículos duplicados.
Ce4	Publicaciones que no correspondan a artículos de revistas o trabajos publicados en congresos y *workshops*.

Proceso de selección de estudios

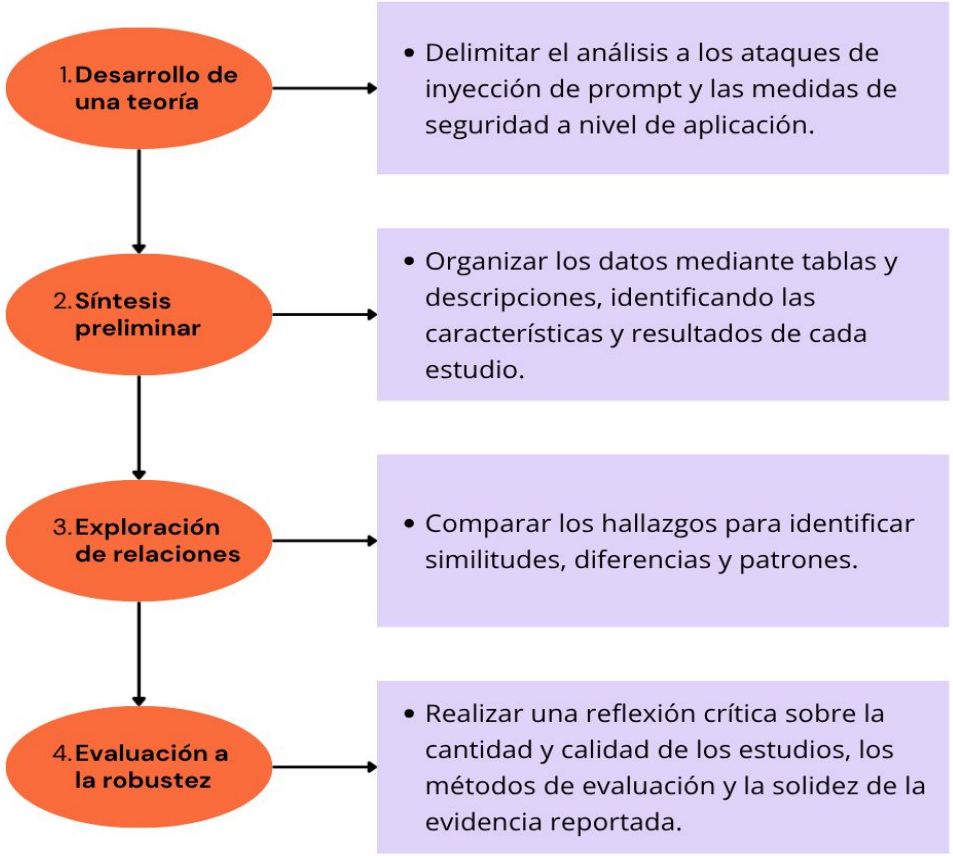


Formato de extracción de datos

Dato	Descripción
Identificador, titulo, autores, año de publicación, tipo de publicación, Venue, DOI, Abstract	Datos bibliográficos
Tipos de inyección de prompt	PI-1
Medidas de seguridad a nivel de aplicación	PI-2
Categorías de las medidas de seguridad	PI-3
Escenarios de implementación	PI-4
Evaluación de efectividad	PI-5
Limitaciones	PI-6
Trabajo futuro	PI-7

Síntesis de información

- Método: Síntesis narrativa, basada en la propuesta de Popay et al. (2006), para organizar, comparar e interpretar los hallazgos de los estudios primarios.



Cronograma

Mes	Octubre				Noviembre				Diciembre				Enero	
Semana	1°	2°	3°	4°	1°	2°	3°	4°	1°	2°	3°	4°	1°	2°
Desarrollo del protocolo de la RSL	■	■	■	■										
Selección de estudios					■	■								
Extracción de datos						■	■							
Metodología de síntesis							■	■	■					
Revisión y ajuste a la síntesis									■	■				
Redacción del reporte											■	■		
Entrega y validación del reporte de RSL por los directores													■	
Entrega y revisión final del reporte por la academia														■

Referencias

- Damacena Duarte, J., Cândido, G. D., de Britto Filho, J. R. A., Souza Neto, J., da Costa, E. J., da Costa, J. P. J., & Peotta De Melo, L. (2026). A Systematic Review of Prompt Injection Attacks on Large Language Models: Trends, Taxonomy, Evaluation, Defenses, and Opportunities. IEEE Access, 14, 12875–12899. https://doi.org/10.1109/ACCESS.2026.3656849
- Geng, T., Xu, Z., Qu, Y., & Wong, W. E. (2026). Prompt Injection Attacks on Large Language Models: A Survey of Attack Methods, Root Causes, and Defense Strategies. Computers, Materials and Continua, 87(1). https://doi.org/10.32604/cmc.2025.074081
- Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. http://arxiv.org/abs/2302.12173
- Kitchenham, B. A., Budgen, D., & Brereton, P. (2015). Evidence-Based Software Engineering and Systematic Reviews (1st ed.). CRC Press. https://doi.org/10.1201/b19467
- Kumar, S. S., Cummings, M. L., & Stimpson, A. (2024). Strengthening LLM Trust Boundaries: A Survey of Prompt Injection Attacks. 2024 IEEE 4th International Conference on Human-Machine Systems (ICHMS). https://doi.org/10.1109/ICHMS59971.2024.10555871
- Popay, J., Arai, L., Rodgers, M., & Britten, N. (2006). Guidance on the conduct of narrative synthesis in systematic reviews: A product from the ESRC Methods Programme. https://doi.org/10.13140/2.1.1018.4643
- Woesle, C., & Buettner, R. (2026). A Systematic Literature Review of Prompt Injection Attacks in LLM-Integrated Systems. IEEE Access, 14, 86797–86818. https://doi.org/10.1109/ACCESS.2026.3700492
- Zhang, H., Babar, M. A., & Tell, P. (2011). Identifying relevant studies in software engineering. Information and Software Technology, 53(6), 625–637. https://doi.org/10.1016/j.infsof.2010.12.0



Universidad Veracruzana

Facultad de Estadística e Informática

Región: Xalapa

Licenciatura en Ingeniería en Ciberseguridad e Infraestructura de Cómputo

Medidas de seguridad a nivel de aplicación en el contexto de ataques de inyección de prompt dirigidos a sistemas basados en LLM: Una revisión de literatura

Presentación de avances de la revisión sistemática de literatura para la EE Proyecto Guiado

Presenta:
Abraham Núñez Sánchez

Director:
Héctor Xavier Limón Riaño

Noviembre 2026

"Lis de Veracruz: Arte, Ciencia, Luz"